

# US Patent & Trademark Office

## Patent Public Search | Text View

---

|                      |                      |
|----------------------|----------------------|
| United States Patent | 12407706             |
| Kind Code            | B2                   |
| Date of Patent       | September 02, 2025   |
| Inventor(s)          | Shavlik; Mark et al. |

---

### Enterprise security assessment and management service for serverless environments

---

#### Abstract

Methods and systems for assessment and management of security in serverless environments are provided. One method includes executing an at least partially automated environment discovery process in which an overall security footprint of the enterprise is determined, and automatically identifying, via an enterprise security assessment tool, one or more security applications and associated settings capable of meeting the set of security requirements of the enterprise based on the sets of attributes associated with a plurality of serverless services.

---

**Inventors:** Shavlik; Mark (White Bear Lake, MN), Dolan; Thomas (Saint Paul, MN)

**Applicant:** Senserva, LLC (Saint Paul, MN)

**Family ID:** 83365164

**Assignee:** Senserva, LLC (Saint Paul, MN)

**Appl. No.:** 17/704914

**Filed:** March 25, 2022

#### Prior Publication Data

|                            |                         |
|----------------------------|-------------------------|
| <b>Document Identifier</b> | <b>Publication Date</b> |
| US 20220311797 A1          | Sep. 29, 2022           |

#### Related U.S. Application Data

us-provisional-application US 63166810 20210326

---

#### Publication Classification

**Int. Cl.:** H04L9/40 (20220101)

**U.S. Cl.:**

**CPC** H04L63/1433 (20130101);

## Field of Classification Search

**CPC:** H04L (63/1433); H04L (63/1425); H04L (63/20); H04L (41/0894); G06F (21/577)

---

## References Cited

### U.S. PATENT DOCUMENTS

| Patent No.   | Issued Date | Patentee Name | U.S. Cl. | CPC          |
|--------------|-------------|---------------|----------|--------------|
| 2019/0007458 | 12/2018     | Shulman       | N/A      | H04L 63/1433 |
| 2021/0194913 | 12/2020     | Hecht         | N/A      | H04L 63/105  |
| 2022/0100854 | 12/2021     | Ahmed         | N/A      | G06F 3/0679  |

### OTHER PUBLICATIONS

Chandrashekar, Karthik, and Vinay Dutt Jangampet. "Risk-Based Alerting in SIEM Enterprise Security: Enhancing Attack Scenario Monitoring Through Adaptive Risk Scoring." International Journal of Computer Engineering and Technology (IJCET) 11.2 (2020): 78-85. (Year: 2020). cited by examiner

---

*Primary Examiner:* Kim; Jung W

*Assistant Examiner:* Wickramasuriya; Sameera

*Attorney, Agent or Firm:* Merchant & Gould P.C.

---

## Background/Summary

CROSS-REFERENCE TO RELATED APPLICATIONS (1) The present application claims priority from U.S. Provisional Patent Application No. 63/166,810, filed on Mar. 26, 2021, the disclosure of which is hereby incorporated by reference in its entirety.

### BACKGROUND

(1) Increasingly, serverless computing environments are utilized by enterprises to allow for flexible remote services to be provided, without the need to worry about local or cloud instances of computing resources. Rather, services are provided in charge on an as-used basis, allowing for automated storage, security, scale, capacity, and operating system type to be automated. This has advantages to end users, because it removes the need to acquire other support services for particular web services, and also removes the headaches with respect to scaling of applications on a realtime, on-demand basis. In particular, end users have no specific computing resources to buy but instead may pay on an as needed as used basis for particular services.

(2) While this arrangement has significant advantages to such end users, it can also introduce significant complexity for enterprises that are typically used to traditional client-server arrangements and which have an obligation to assess and manage network security across all devices and applications that access sensitive data. While in the typical context, security

assessment and monitoring tools are available, enterprises that utilize serverless application resources typically would not be exposed to the underlying security features of those serverless implementations (which would typically be managed instead directly by cloud or on-premise vendors that supply serverless resources), but may still need to be able to assess and/or manage security at some level.

(3) This difficulty in terms of resource security management is exacerbated in the serverless context because serverless applications or services may be executed across any of a number of cloud platforms each having different configuration and security parameters and standards. Setting up security for each of these types of services can require significant time and effort. Because industry trends increasingly mean that IT workers have less education or training, it is often the case that enterprise personnel who are tasked with managing serverless security will not have the significant level of training or knowledge that is required to be able to configure such applications.

(4) Still further, it can be difficult to determine the scope of any security vulnerability that may be present within an organization in the absence of further user tools that assist in highlighting such potential issues before they might occur.

(5) Accordingly, improvements in terms of flexibility of security management and exposure to security assessment information is desirable for such enterprises.

## SUMMARY

(6) In general, the present application relates to an enterprise security assessment and management service that is usable in serverless or partially serverless computing environments. In example implementations, assessment and reporting on security issues is provided to automatically, for example based upon an assessment of an enterprise, comparison of the enterprise to other similarly situated enterprises, or comparison to other standards. Automated adjustments to security settings, for example using robotic process automation, or other automated task execution units, may also be provided.

(7) In a first aspect, a method of automatically managing enterprise security for an enterprise utilizing at least one serverless service is disclosed. The method includes executing an at least partially automated environment discovery process in which an overall security footprint of the enterprise is determined, the overall security footprint including a set of security requirements based on characteristics of the enterprise and a set of attributes associated with each of a plurality of serverless services utilized by the enterprise. The method further includes automatically identifying, via an enterprise security assessment tool, one or more security applications and associated settings capable of meeting the set of security requirements of the enterprise based on the sets of attributes associated with the plurality of serverless services.

(8) In a second aspect, an enterprise security assessment tool stored in a memory and executable on a computing device is disclosed. The tool includes an application programming interface (API) providing a communicative connection to computing resources of an enterprise, the enterprise utilizing a plurality of serverless services. The tool further includes an assessment engine configured to execute an at least partially automated environment discovery process in which an overall security footprint of the enterprise is determined, the overall security footprint including a set of security requirements based on characteristics of the enterprise and a set of attributes associated with each of the plurality of serverless services utilized by the enterprise, and automatically identify one or more security applications and associated settings capable of meeting the set of security requirements of the enterprise based on the sets of attributes associated with the plurality of serverless services.

(9) A variety of additional aspects will be set forth in the description that follows. The aspects can relate to individual features and to combinations of features. It is to be understood that both the foregoing general description and the following detailed description are exemplary and explanatory only and are not restrictive of the broad inventive concepts upon which the embodiments disclosed herein are based.

---

## Description

### BRIEF DESCRIPTION OF THE DRAWINGS

- (1) The following drawings are illustrative of particular embodiments of the present disclosure and therefore do not limit the scope of the present disclosure. The drawings are not to scale and are intended for use in conjunction with the explanations in the following detailed description. Embodiments of the present disclosure will hereinafter be described in conjunction with the appended drawings, wherein like numerals denote like elements.
- (2) FIG. 1 illustrates an example environment in which aspects of the present disclosure may be implemented.
- (3) FIG. 2 illustrates an example block diagram of a serverless security assessment tool according to an example embodiment of the present disclosure.
- (4) FIG. 3 illustrates a block diagram of a computing system with which aspects of the present disclosure may be implemented.
- (5) FIG. 4 illustrates an overall process flow chart for assessment and management security in a serverless or partially serverless environment according to aspects of the present disclosure.
- (6) FIG. 5 illustrates a process flow chart for profiling an enterprise including a serverless or partially serverless environment according to aspects of the present disclosure.
- (7) FIG. 6 illustrates a process flow chart for determining advisable security settings for an enterprise including a serverless or partially serverless environment according to aspects of the present disclosure.
- (8) FIG. 7 illustrates an example security report that is capable of being generated by the serverless security assessment tool of the present disclosure.
- (9) FIG. 8 illustrates example automated processes performed by or initiated by the serverless security assessment tool of the present disclosure.
- (10) FIG. 9 illustrates an environment in which serverless security assessment is performed for a particular enterprise, according to an example embodiment.
- (11) FIG. 10 is an example application scan user interface displayed via the serverless security assessment tool, according to an example embodiment.
- (12) FIG. 11 is an example conditional access scan user interface displayed via the serverless security assessment tool, according to an example embodiment.
- (13) FIG. 12 is an example compliance scan user interface displayed via the serverless security assessment tool, according to an example embodiment.
- (14) FIG. 13 is an example user scan interface displayed via the serverless security assessment tool, according to an example embodiment.
- (15) FIG. 14 illustrates an example security threat report presentable within an example user interface displayed via the serverless security assessment tool.
- (16) FIG. 15 illustrates an example threat dashboard presentable within an example user interface displayed via the serverless security assessment tool.

### DETAILED DESCRIPTION

- (17) Various embodiments of the present invention will be described in detail with reference to the drawings, wherein like reference numerals represent like parts and assemblies throughout the several views. Reference to various embodiments does not limit the scope of the invention, which is limited only by the scope of the claims attached hereto. Additionally, any examples set forth in this specification are not intended to be limiting and merely set forth some of the many possible embodiments for the claimed invention.
- (18) As briefly described above, embodiments of the present invention are directed to systems and methods for automated security assessment, monitoring, and reporting in serverless environments. In example aspects, the present application relates to a serverless service configured to assess and

report on security issues within a serverless environment. In example embodiments the serverless security assessment service is serverless environment agnostic, meaning that it is capable of operating within any of a variety of cloud environments provided by different cloud providers. (19) In example implementations, an assessment, profiling, and reporting arrangement may be provided by the serverless service that accommodates both on-premises and cloud physical device security and serverless service or application security. In example embodiments, modeling of similar enterprises and automated process technology may be used to automatically address particular security issues that may be detected within the enterprise. Accordingly, unified, cross cloud automated security may be provided for serverless computing and cloud users while limiting the need for specialized training for enterprise information technology professionals.

(20) The present disclosure is directed to a multi-tenant Cloud Security Posture Management tool that simplifies the removal of cloud security risks before they become problems by continually producing priority-based risk assessments. The tool, as described herein, focuses on account role access and privilege risks, and performs a detailed security ranking for all the Azure objects that are managed by the tool. This enables users to perform optimal discovery and remediation by fixing the most critical issues with the highest impact items first. In an example application, the tool uses 37 different APIs for Azure Active Directory analysis.

(21) Recommendations and management interfaces are created using a combination of industry recommendations, vendor recommendations and experts. This information is then driven by industry standards including NIST 800-53 and MITRE ATT&CK. The tool may be executed as a stand alone security risk management tool or may coexist with other solutions. As described herein, the tool continually finds highest priority issues/problems in an existing Azure account as things change in an enterprise cloud environment by combining the work of security industry experts, industry resources such as vendor How-To guides and risks determined by experts, followed by determining in detail all the data that can be returned from a secured cloud instance to assure all possible information is used.

(22) These results through Machine Learning algorithms to rapidly perform complex analysis, combines those results with industry standards described above, and filters/sorts and focuses users on critical issues while providing a continual, unified security assessment. Further, the tool does not require removal of any security data from an enterprise cloud instance.

(23) The tool described herein is particularly advantageous for complex enterprises. Often, cloud user accounts alone have hundreds of security combinations and those accounts are directly affected by all other Azure Active Directory components. These related AAD components also have 100s of configuration combinations making it nearly impossible to know what to give and what to take away. Given this complexity, the tendency is for administrators to overcredential users for simplicity.

(24) Additionally, it can be difficult to know and to manage properly security configuration states as well as which tools to use and when. With security norms and configurations always changing inside and outside Azure and at Cloud vendors, it can be difficult for an enterprise to stay current as to best security practices.

(25) In example embodiments, the serverless security tool described herein continually gives a security grade to each element of a cloud environment, such as Azure Active Directory. The tool then cross references these grades across all related Azure Active Directory components. For example, administrative users are reviewed by the Azure AD Applications they manage, if an application is not well secured then that administrative user is marked as more of a security risk than originally thought and the user is given a new security score. This process is continually repeated across Azure AD security components and tenants, providing continuous security configuration feedback via a controls dashboard.

## I. Serverless Security Assessment Tool Environment and Architecture

(26) Referring first to FIG. 1, an example environment **10** in which aspects of the present

disclosure may be implemented is shown. In the example environment **10**, of an enterprise may be associated with one or more enterprise premises **12**. Enterprise premises **12** correspond to physical locations of the enterprise, which may store various types of computing resources. For example, multiple physical computing networks, database systems, user devices, etc. may be managed therein. Additionally, such enterprise premises **12** may be interconnected via a public network **14**, such as the Internet. The enterprise may also accommodate remote devices such as mobile devices **16** and remote workstations **18**. Additionally, various cloud providers of different types may be utilized by the enterprise. In the example shown, a generic cloud **20** illustrates various cloud computing resources, such as servers and data storage. The cloud resources may be provided by one or more cloud providers, who may also provide serverless services for additional scalability and convenience. For example, cloud services provided by Amazon Web Services (AWS) and or Microsoft Azure may be utilized by the same enterprise, and security considerations relevant to both cloud services must be considered. Additionally, each cloud service provider may provide separate types of serverless services, which have different security needs (both from the perspective of the services provided being different, and from the perspective that each serverless service may be configured differently by different enterprises).

(27) In the example shown, a security assessment tool **100** is provided. The security assessment tool **100** may be, in example implementations, managed within a cloud storage service. In alternate implementations, the security assessment tool **100** may be managed from a local or remote computing system that is not managed by cloud services (e.g., seen as a local version of the security assessment tool **100'**). In some examples, only a portion of the security assessment tool is maintained at the enterprise premises, for example, one or more bots or user interface components that are described below.

(28) In the various implementations, the security assessment tool **100** is configured to determine cross cloud and on-premises security needs for serverless services, such as administrator accounts, non-administrator accounts, monitoring, logging and other common security needs. This is accomplished, in some cases, by automated detection, or by simple questions asked of an enterprise information technology professional. Still further, and as described herein, the security assessment tool **100** is also configured to determine the number of user accounts and what other services are being used. Once the security needs are understood, the security assessment tool **100** is configured to report on how the security services that help serverless computing, provided by the cloud or other vendors can be used, can be properly used. If a service is being used, it is inspected for proper user use, or if it is required by the enterprise at all, based on automatically-assessed enterprise needs.

(29) In examples, various users may access enterprise resources managed using serverless systems. In such arrangements, users, such as user **U1** and user **U2** at devices **16**, **18**, respectively, may be within or external to the enterprise. One or both of users **U1**, **U2** may be an administrative user having access to the security assessment tool **100**; in general, both users **U1**, **U2** will access such resources and access logs representing user activity may be captured by the enterprise and used by the security assessment tool **100** as described below.

(30) Referring now to FIG. **2**, an example of a security assessment tool **100** is illustrated, according to an example embodiment. In the example shown, the security assessment tool **100** includes a plurality of application programming interfaces (APIs) including a survey API **201**, an assessment API **202**, and a remediation API **203**. In addition, the security assessment tool can include a user interface **204** and an assessment engine **206**. In addition, the security assessment tool may either store or manage a data storage attribute database **210**, robotic process automation systems **212**, and one or more security models **214**.

(31) In example embodiments, the APIs **201-203** provide an access interface by which users may interact with the security assessment tool **100**. For example, the survey API **201** allows for remote access of the security assessment tool **100** to survey security settings of the enterprise. Assessment

API **202** provides access to assessment features of the security assessment tools, such as are provided by the assessment engine **206**, described below. Additionally, the remediation API **204** may provide access to not only the assessment engine **206**, but also to initiate usage of robotic process automation systems **212** and/or security models **214** for purposes of initiating security remediation steps, either manually or automatically, as noted below.

(32) In example embodiments, the user interface **204** provides an information technology user with a view of an enterprise security assessment. For example, the user interface **202** may present to the user one or more prompts that allow the user to define an enterprise topology including data storage locations and data access rights, an enterprise user base, data storage requirements the enterprise is subject to (e.g., HIPAA, PCI data storage), local and cloud computing resources used, as well as serverless services integrated by the enterprise and other types of enterprise specific information. The user interface **204** may also present to the user a report regarding specific types of security concerns, as well as a score for the enterprise based on a current status of the enterprise (e.g., relative to a predetermined standard or other similarly situated enterprises), and one or more recommended actions to be taken.

(33) In the example embodiments, the assessment engine **206** is configured to direct a guided or automated security assessment process for a particular enterprise that utilizes one or more serverless services. For example, the assessment engine **206** may be configured to determine a security footprint of a selected enterprise, including a set of security requirements based on characteristics of the enterprise and attributes of serverless services used by the enterprise that are either automatically determined or input to the assessment engine **206** via the user interface **204**. Additionally, the assessment engine **206** may, following such a discovery process, automatically identify security applications and associated settings capable of meeting security requirements of the enterprise based on the attributes of the serverless services and the characteristics of the enterprise. The assessment engine **206** may, for example, discover and review event logs associated with one or more services utilized by the enterprise, such as serverless services and other types of services (e.g., database event logs, access logs, etc.).

(34) In example embodiments, the assessment engine **206** may execute continuously or periodically, thereby providing a continuous or ongoing assessment security for serverless services utilized by an enterprise. Accordingly, as such services may change or as different services are added by the enterprise, the assessment engine **206** may automatically detect and recommend changes to or additions to security settings or applications that are used by that enterprise.

(35) In example embodiments, the assessment engine **206** may directly monitor one or more enterprises in accordance with the functionality described herein. However, in alternative embodiments, the assessment, monitoring, recommendation, and action taking can be offloaded to one or more bots implementing robotic process automation tasks, for example as illustrated in FIG. **9** and discussed below.

(36) As noted above, the security assessment tool **100** may access a data storage attribute database **210**. The data storage attribute database **210** may be managed by the security assessment tool **100** directly, or may be accessed from a remote location (e.g., from within the enterprise being assessed). The data stored at the database **210** cannot store the data captured via the user interface **204** or one or more APIs **201-203**, as well as information automatically captured based on an assessment of an enterprise. Additionally, the data storage attribute database **210** may store attributes describing other enterprises, for example for comparison purposes. The data storage attribute database **210** may be utilized by the assessment engine **206** for purposes of storing characteristics or attributes of the enterprise or serverless services utilized by the enterprise, for purposes of future analysis.

(37) It is noted that, in many embodiments, the data storage attribute database **210** may store select customer data, anonymous data, or other types of data descriptive of the enterprise, but typically will not store any enterprise security configuration data. This ensures that use of the security

assessment tool does not cause additional security vulnerability exposure to the enterprise.

Generally, to the extent enterprise security configuration data is obtained during assessment of the enterprise (or other enterprise-specific security

(38) In the example shown, the security assessment tool **100** may also include or have access to one or more robotic process automation systems **212**. The security assessment tool **100** may use such systems **212** to automatically configure various security settings of an enterprise based on the assessment performed by the assessment engine **206**. For example, the one or more robotic process automation systems **212** may be usable to monitor existing security settings, recommend and install new security solutions, and remove solutions that may no longer be needed.

(39) In example embodiments, the robotic process automation systems **212** may be maintained by each enterprise, or alternatively may be maintained by the entity providing the security assessment tool **100**. The robotic process automation systems **212**, in either case, may be maintained separately from the tool **100**, but accessible from and integrated with the tool.

(40) In the embodiment shown, one or more security models **214** may be managed by or accessible to the security assessment tool **100**. The security models may be, for example, derived models that are generated from mathematical abstractions other, the modeled enterprises and their related security settings. For example, data stored in a data storage attribute database **210** may be used to generate one or more models using, for example, a statistical algorithm and/or convolution neural networks (CNNs). Such models may be used to obtain a recommended set of security settings and security attributes for the enterprise, or may be used to generate scores associated with particular attributes of the enterprise and recommended changes to security settings. Such attributes and security settings may be updated periodically, and therefore the security assessment tool **100** may ensure secure access to server less services on a real time or periodic basis.

(41) In some embodiments, the security assessment tool **100** may implement and deploy one or more automated bots which may be implemented using the robotic process automation systems **212** and optionally one or more security models **214**. For example, a web crawler bot or rule based automation bot may be deployed to analyze an enterprise, in particular focused on profiling the enterprise and automating security assessment and security policy application tasks.

(42) The security assessment tool **100** solves a problem that, typically, large organizations do not realize that they have. Accordingly, it may be difficult to assess the extent to which security concerns exist, and such concerns only appear after an assessment is performed. Identification of security problems, or potential vulnerabilities, may require waiting for user logs to arrive and be assessed based on actual user activity.

(43) In example implementations, a simulator, such as cloud simulation component **220**, may be provided within the security assessment tool **100** or separately therefrom. The cloud simulation component **220** simulates operation of the cloud component. A set of synthetic user logs **222** may then be generated from interactions with the simulated cloud component **220**. The synthetic user logs **222** may be provided to other aspects of the security assessment tool **100**, which will then highlight, for a given organization, particular security concerns before they may arise.

(44) This allows for security concerns to be debugged in advance of those concerns actually arising. A set of policies may be assessed for the server component based on user configuration and different security settings, as derived from scenarios exposed by synthetic user logs generated through simulation.

(45) In a particular example, a user may be a well-known user acting within a enterprise network. In such circumstances, the user may not be presented with MFA authentication requirements. In other circumstances, a user may not be as well known, and may be positioned outside the enterprise network, for example at an international location. In such instances, the user may be entirely blocked from access. In a third example, a user may be known, but positioned outside the enterprise network, and therefore may be presented with MFA requirements. By simulating these different reactions to the user authentication attempts at the cloud component **220**, the synthetic



user logs **222** may be generated and assessed to determine potential vulnerabilities.

(46) Referring now to FIG. **3**, a computing device **300** is shown, with which aspects of the present disclosure can be implemented. The computing device **300** can be used, for example, to implement any of the cloud and/or enterprise computing devices of FIGS. **1-2**.

(47) In the example of FIG. **3**, the computing device **300** includes a memory **302**, a processing system **304**, a secondary storage device **306**, a network interface card **308**, a video interface **310**, a display unit **312**, an external component interface **314**, and a communication medium **316**. The memory **302** includes one or more computer storage media capable of storing data and/or instructions. In different embodiments, the memory **302** is implemented in different ways. For example, the memory **302** can be implemented using various types of computer storage media, and generally includes at least some tangible media. In some embodiments, the memory **302** is implemented using entirely non-transitory media.

(48) The processing system **304** includes one or more processing units, or programmable circuits. A processing unit is a physical device or article of manufacture comprising one or more integrated circuits that selectively execute software instructions. In various embodiments, the processing system **304** is implemented in various ways. For example, the processing system **304** can be implemented as one or more physical or logical processing cores. In another example, the processing system **304** can include one or more separate microprocessors. In yet another example embodiment, the processing system **304** can include an application-specific integrated circuit (ASIC) that provides specific functionality. In yet another example, the processing system **304** provides specific functionality by using an ASIC and by executing computer-executable instructions.

(49) The secondary storage device **306** includes one or more computer storage media. The secondary storage device **306** stores data and software instructions not directly accessible by the processing system **304**. In other words, the processing system **304** performs an I/O operation to retrieve data and/or software instructions from the secondary storage device **306**. In various embodiments, the secondary storage device **306** includes various types of computer storage media. For example, the secondary storage device **306** can include one or more magnetic disks, magnetic tape drives, optical discs, solid-state memory devices, and/or other types of tangible computer storage media.

(50) The network interface card **308** enables the computing device **300** to send data to and receive data from a communication network. In different embodiments, the network interface card **308** is implemented in different ways. For example, the network interface card **308** can be implemented as an Ethernet interface, a token-ring network interface, a fiber optic network interface, a wireless network interface (e.g., WiFi, WiMax, etc.), or another type of network interface.

(51) The video interface **310** enables the computing device **300** to output video information to the display unit **312**. The display unit **312** can be various types of devices for displaying video information, such as an LCD display panel, a plasma screen display panel, a touch-sensitive display panel, an LED screen, a cathode-ray tube display, or a projector. The video interface **310** can communicate with the display unit **312** in various ways, such as via a Universal Serial Bus (USB) connector, a VGA connector, a digital visual interface (DVI) connector, an S-Video connector, a High-Definition Multimedia Interface (HDMI) interface, or a DisplayPort connector.

(52) The external component interface **314** enables the computing device **300** to communicate with external devices. For example, the external component interface **314** can be a USB interface, a FireWire interface, a serial port interface, a parallel port interface, a PS/2 interface, and/or another type of interface that enables the computing device **300** to communicate with external devices. In various embodiments, the external component interface **314** enables the computing device **300** to communicate with various external components, such as external storage devices, input devices, speakers, modems, media player docks, other computing devices, scanners, digital cameras, and fingerprint readers.

(53) The communication medium **316** facilitates communication among the hardware components of the computing device **300**. The communications medium **316** facilitates communication among the memory **302**, the processing system **304**, the secondary storage device **306**, the network interface card **308**, the video interface **310**, and the external component interface **314**. The communications medium **316** can be implemented in various ways. For example, the communications medium **316** can include a PCI bus, a PCI Express bus, an accelerated graphics port (AGP) bus, a serial Advanced Technology Attachment (ATA) interconnect, a parallel ATA interconnect, a Fiber Channel interconnect, a USB bus, a Small Computing system Interface (SCSI) interface, or another type of communications medium.

(54) The memory **302** stores various types of data and/or software instructions. The memory **302** stores a Basic Input/Output System (BIOS) **318** and an operating system **320**. The BIOS **318** includes a set of computer-executable instructions that, when executed by the processing system **304**, cause the computing device **300** to boot up. The operating system **320** includes a set of computer-executable instructions that, when executed by the processing system **304**, cause the computing device **300** to provide an operating system that coordinates the activities and sharing of resources of the computing device **300**. Furthermore, the memory **302** stores application software **322**. The application software **322** includes computer-executable instructions, that when executed by the processing system **304**, cause the computing device **300** to provide one or more applications. The memory **302** also stores program data **324**. The program data **324** is data used by programs that execute on the computing device **300**.

(55) Although particular features are discussed herein as included within an electronic computing device **300**, it is recognized that in certain embodiments not all such components or features may be included within a computing device executing according to the methods and systems of the present disclosure. Furthermore, different types of hardware and/or software systems could be incorporated into such an electronic computing device.

(56) In accordance with the present disclosure, the term computer readable media as used herein may include computer storage media and communication media. As used in this document, a computer storage medium is a device or article of manufacture that stores data and/or computer-executable instructions. Computer storage media may include volatile and nonvolatile, removable and non-removable devices or articles of manufacture implemented in any method or technology for storage of information, such as computer readable instructions, data structures, program modules, or other data. By way of example, and not limitation, computer storage media may include dynamic random access memory (DRAM), double data rate synchronous dynamic random access memory (DDR SDRAM), reduced latency DRAM, DDR2 SDRAM, DDR3 SDRAM, solid state memory, read-only memory (ROM), electrically-erasable programmable ROM, optical discs (e.g., CD-ROMs, DVDs, etc.), magnetic disks (e.g., hard disks, floppy disks, etc.), magnetic tapes, and other types of devices and/or articles of manufacture that store data. Communication media may be embodied by computer readable instructions, data structures, program modules, or other data in a modulated data signal, such as a carrier wave or other transport mechanism, and includes any information delivery media. The term “modulated data signal” may describe a signal that has one or more characteristics set or changed in such a manner as to encode information in the signal. By way of example, and not limitation, communication media may include wired media such as a wired network or direct-wired connection, and wireless media such as acoustic, radio frequency (RF), infrared, and other wireless media.

(57) It is noted that, in some embodiments of the computing device **300** of FIG. **3**, the computer-readable instructions are stored on devices that include non-transitory media. In particular embodiments, the computer-readable instructions are stored on entirely non-transitory media.

(58) Referring now to FIGS. **4-8**, additional details regarding operation of a security assessment tool **100** are provided, according to example embodiments. Referring specifically to FIG. **4**, an overall method **400** of operation of such a security assessment tool is provided. In the example

shown, the security assessment tool may be utilized to profile a selected enterprise (step **402**). Profiling the enterprise may include, for example, review of the event logs to determine locations of data, data attributes, user identities and roles, types of services used by the enterprise, data the security measures and requirements, and various other enterprise attributes. In particular examples, profiling the enterprise can include assessment of physical security, review of event logs to determine data access, review of remote access activity, evaluation of sever configuration control, review of virus scan results, analysis of data backup policies and practices, hardware replacement policies and practices, remote management tools, server resource usage, password strength requirements, storage fault tolerance, equipment integrity, and various other types of enterprise attributes.

(59) Profiling the enterprise may be performed, for example, in an at least partially automated manner. In some examples, profiling may involve a guided question and answer process with an information technology professional; in alternative examples the profiling may also involve an automated discovery process. In other embodiments, profiling may be performed, at least in part, using one or more bots operationally interfaced to the enterprise and controlled via the security assessment tool **100**, as noted above.

(60) In the example shown, the method **400** further includes determining advisable security settings for the enterprise (step **404**). This may be accomplished in a variety of ways. For example current enterprise attributes and settings may be compared to those of similarly situated enterprises or may be assessed and scored according to an objective scoring system. Example advisable actions can include, for example, enforcing strong authentication for administrators, or removing certain administrators; removing inactive user accounts; changing a password management policy or enforcing stronger passwords; recommending changes to vendor security management solutions or configurations of those solutions; One example of a report illustrating such a scoring system is seen below in connection with FIG. 7. However, in alternative examples, the advisable security settings may be delivered in other report forms or via notifications on a real-time or near real-time basis. For example, the security assessment tool can initiate notifications directly from that tool, or from existing notification solutions (e.g., Azure Notification Hubs, pushjs, etc.)

(61) Still further, the method **400** can include configuring and inspecting one or more security applications associated with the enterprise (step **406**). This can include, for example, applying one or more recommended settings for security applications that are associated with serverless services used by the enterprise, as well as storing a historical footprint of the enterprise alongside the settings determined to be appropriate for that footprint. Accordingly, as a footprint of the enterprise changes (e.g., based on changes in data storage, changes in users, or changes in serverless services utilized) the footprint may be re-analyzed by re-profiling the enterprise to determine a new set of advisable security settings and reconfiguring the security settings of that enterprise.

(62) Referring to FIG. 5, a method **500** of profiling a selected enterprise is provided. The method **500** may be, for example, one way in which the step **402** of method **400** may be accomplished. In the example shown, the method **500** includes obtaining enterprise attributes (step **502**) which can be accomplished through an at least partially automated process by which the security assessment tool **100** determines a set of enterprise attributes. The enterprise attributes can include, for example, the users associated with the enterprise and the access rights required by those users; operational requirements of the enterprise; enterprise facility definitions and access rights to those facilities; physical locations and data security regulation compliance requirements; business activities and priorities; and various other types of enterprise attributes.

(63) In the example shown, the method **500** further includes obtaining a data footprint of the enterprise (step **504**). Obtaining the data footprint of the enterprise can include performing a data exploration process by the security assessment tool **100** to determine locations at which data is stored within the enterprise, including on-premise and cloud storage. It can also include determining access rights to each data storage location and users associated with the various data

storage locations.

(64) In addition, the method **500** can further include determining security sensitivities of the enterprise, and optionally comparing the enterprise attributes and sensitivities to other, comparable enterprises (step **506**). The security sensitivities may include, for example, security requirements defined by local law or regulation based on a type of user accessing data, type of data being accessed, or type of processing to be performed by the enterprise (e.g., handling HIPAA or PCI data, compliance with the General Data Protection Regulation (GDPR) and/or California Consumer Privacy Act (CCPA), etc.). Comparison of similarly situated or compare below enterprises may include, for example, comparing security settings for two enterprises subject to HIPAA or PCI data security requirements, or otherwise comparing enterprises based on similarity of attributes to determine similarities or best practices regarding security services and/or settings used.

(65) Generally, the method **500** represents assessment of an enterprise if such that one or more reports of the current state of security of serverless services used by the enterprise may be generated, and recommended action items provided. In addition, as further discussed below, actions to directly modify security features of an enterprise may be taken by the security assessment tool **100**.

(66) Referring now to FIG. **6**, a method **600** of determining advisable security settings for an enterprise, such as an enterprise utilizing serverless services, is disclosed. In the example shown, the method **600** includes assessment of event logs managed by the enterprise (step **602**), for example accesses of serverless services, as well as accesses of data managed by the enterprise either in cloud or on premise. The method further includes displaying changes in security and enterprise profiles (step **604**).

(67) The method **600** further includes generating a report regarding a current score for the enterprise (step **606**). The current score may be based, at least in part, on comparison of the current security measures taken as compared to either other similarly situated enterprises or to an ideal or recommended set of security settings. Optionally, the report may also include information regarding an impact of changes to security settings on that score (e.g., whether the score would increase or decrease, an amount of increase or decrease, etc.).

(68) As seen in FIG. **7**, an example report **700** is provided in a user interface of a computing system. The example report **700** may be generated, for example, upon execution of the method **600** of FIG. **6**. In the example report **700** as shown, security features of an enterprise may be analyzed, as well as possible changes to security settings on the specific type of security feature that is an office. For example a change to a security feature such as reducing a number of administrative users may have a high impact or effect on users, may require comparatively little effort, and moderate impact. Such a change may result in a drastic improvement in score, as shown by the scoring value scene. However, a comparatively minor change, such as slowing down servers on a Sunday, may still have a high effect on users, but relatively low impact for particular types of enterprises. For example any retailer if not selling football gear or sports related memorabilia may not see a great impacts to such a change.

(69) Referring now to FIG. **8**, a method **800** is shown for configuring and inspecting an enterprise security settings footprint, including serverless security settings. The method **800** can be used, for example, to accomplish step **406** of the method described above in FIG. **4**.

(70) In the example shown, method **800** includes a plurality of operations, which may be performed in any of a variety of orders. The method can include, for example, validating physical security of enterprise locations and other locations managing enterprise data and operations (step **802**). This can include, for example, both validating physical security of enterprise locations, as well as investigating event logs relating to physical access. The method can further include investigating and managing authentication and user account access (step **804**). This can include, for example, utilizing one or more bots defined within or controlled by the security assessment tool **100** to monitor each of the enterprise locations, including a user bot that can be utilized to act as a user to

assess enterprise locations and set/modify security settings. The method can also include investigating in managing passwords and multi factor authentication settings (step **806**), which similarly may be performed by such a user bot or an admin bot, as described below.

(71) In the example shown, the method further can include assessing vendor security solutions and services, including configurations of such solutions and services (step **808**). This can include, for example, updating service packs and/or patches to software, ensuring that fender security management solutions are activated, set up, and actively managed. The method further includes assessing fault tolerance and physical integrity of enterprise facilities and systems, and utilization of robotic process automation for automated maintenance activities that are to be performed on security infrastructure of the enterprise (step **810**). Such processes may be performed by the user bot as noted above, or in the case of assessment of serverless services, may be performed by vendor product management bots **240** which are defined to be

(72) Referring generally to FIGS. **4-8**, it is noted that, in some embodiments, the processes described may be performed in varying orders or may be performed cyclically, such that a constant process of monitoring, recommendation, and automated maintenance may be provided by the security assessment tool **100**. In this way, serverless services may be ensured to be assessed for purposes of securing those services and data associated with the services, while allowing enterprise users to receive reports comparing their enterprise to other similarly situated enterprises, areas of potential improvement in securing serverless services and other on-premise or cloud computing resources.

## II. Serverless Security Assessment Tool Example Environment and User Interfaces

(73) FIG. **9** illustrates an environment **900** in which serverless security assessment is performed for a particular enterprise, according to an example embodiment. In the example shown, a security assessment tool **100** is configured to interact with various enterprise resources, including on-premise enterprise resources **902**, cloud providers **20a-20b** of the enterprise, as well as one or more serverless services **910** that are utilized by the enterprise.

(74) In the example shown, the security assessment tool **100** can generally include the components described above in connection with FIG. **2**; however, when deployed against a particular enterprise, one or more bots may be used to perform security assessment tasks. For example, an admin bot **220** may be used to perform administrative tasks relative to enterprise monitoring, such as controlling other bots, initiating scans of logs or other assessment tasks, and managing timing of the cyclical, periodic assessment and remediation processes described herein. Additionally, one or more user bots **230** may be used to automate processes otherwise performed manually, e.g., performing assessment of event logs, review of policies, etc. Such user bots may be defined as special-purpose, single purpose bots that are reusable to perform similar tasks across enterprises and are scalable according to enterprise size and/or needs.

(75) Furthermore one or more vendor product management bots **240** may be used. In example implementations, separate vendor product management bots **240** may be dedicated to each serverless service that may be used by the enterprise, as well as optionally each of the cloud providers. In this way, the vendor product management bots **240** may be reused across different enterprises with little customization, and can readily scale as more or fewer serverless services are used by each enterprise.

(76) In example implementations, the serverless security tool described herein uses small, asynchronous, light and fast single purpose Cerbos to implement some or all of the bots described herein. The Cerbos continually look for security configuration changes modeling cloud security. Each Cerbo is responsible for the security configuration management of one set of items, and remains single purposed and focused on those items for monitoring and management. Cerbos generate thousands of numerical security scores to identify and grade security configurations. The Cerbos model component relationships and dependencies with a follower's model, where Cerbos message each other of security configuration changes in real time. Exchanged data is deduplicated,

and only new changes to a cloud configuration are analyzed. The Cerbos are configured to read from a variety of cloud or local environments, such as AWS, Google, Azure, Windows and Linux. The Cerbos may all be active at the same time, either scheduled independently or running together and interoperationally. Each Cerbo can output an actionable control presented at a tool user interface described herein, and may be persisted across changes and/or restarted if crashed without affecting overall operation of the tool.

(77) When assessing the clouds **20a-b**, the security assessment tool may, via the admin bot **220** or user bot, assess a vendor profile of the cloud provider, e.g., what security and automation tools the vendor provides, vendor license costs, roll out costs, criticality of the solution, alternative products, and availability of automation for various tasks within the cloud of that cloud provider.

(78) In example embodiments, any cloud Restful APIs that are available and documented are accessed to obtain data relevant to a target configuration. Additionally, events are used to help profile an enterprise's serverless security footprint.

(79) In still further example embodiments, the bots described herein are persisted, in that they remain running indefinitely and transmit messages with each other when changes in a cloud configuration of a particular enterprise is detected. In response to a change, a rescan by one or all bots may be performed.

(80) In particular embodiments, current state is maintained within the tool (e.g., in a private data store within the customer's data center), with only new information aggregated as changes occur. In some cases, the entire data store of security data may be rebuilt periodically, e.g., weekly.

(81) In example implementations described below in conjunction with user interfaces presented in FIGS. **9-15**, a control name, unique identifier, tenant that generated the control, and date or generation may be displayed. Additionally, possible errors are presented that occurred during generation. A scan identifier is created that contains the source of a scan, and includes a description of any issue, details, and a reason for a score (examples of which are seen in FIG. **14**, below). As illustrated below, the user interfaces may be presented on a user device, such as user devices **16**, **18**, to an administrative user U.

(82) References with more control related information, and how to fix an identified issue, may be provided as well, alongside a criticality (Severe to Informational) and specific control values such as a username, groupname, and type of control can be provided. Each issue may be weighted by severity as well, as seen herein.

(83) Referring now to FIGS. **10-13**, example user interfaces are presented that may be displayed based on access of and assessment by the securing assessment tool. For example, an admin bot **220**, user bot **230**, or vendor product management bots **240** may be used to provide assessment data to a serverless service **910** which may be accessible and generate user interfaces such as are shown.

(84) FIG. **10** is an example application scan user interface **1000** displayed via the serverless security assessment tool, according to an example embodiment. In the example shown, the application scan user interface **1000** includes regions in which a user may select specific users, conditional access rights, applications, enhanced compliance, or a license review. In the user interface **1000** specifically, the "applications" field is selected, and a listing of detected applications present within the serverless environment are presented, as well as the types of applications, and specific risks posed by each application (illustrated near an "impact" bar in the form of a bar chart ordered in decreasing order of importance). Additionally, a conditional access field allows a user to view where conditioned access to the particular application is established, and what conditions/users are granted such access rights. Accordingly, on a per-application basis, a risk assessment may be performed (e.g., number of permissions, impact of those permissions, etc.) and displayed in a user-friendly manner to an administrator.

(85) FIG. **11** is an example conditional access scan user interface **1100** displayed via the serverless security assessment tool, according to an example embodiment. The conditional access scan user interface **1100** may be presented, for example in response to selection of the conditional access

rights option in the application scan user interface **1000** (or analogous options in user interfaces of FIGS. **12-13**). In the example shown, the conditional access scan user interface **1100** displays various conditional access methodologies in place within an enterprise, controls, state, conditions, and grants of rights within that particular conditional access methodology. Examples shown include an overall score, a requirement to user multifactor authentication on a phone, a requirement to include application protection, a limit on a number of sign-in attempts per hour, and a requirement of a compliant device. Other types of methodologies derived from a scan may be provided as well.

(86) FIG. **12** is an example compliance scan user interface **1200** displayed via the serverless security assessment tool, according to an example embodiment. The compliance scan user interface **1200** may be presented in response to selection of an “enhanced compliance” option within a set of presented options. The user interface **1200** presents a number of policies that may be adopted, controls useable to adjust those policies, a score associated with each policy, a total score out of possible scores, and recommendations to improve security over an entire enterprise.

(87) FIG. **13** is an example user scan interface **1300** displayed via the serverless security assessment tool, according to an example embodiment. In this example interface, each user authorized with a particular role within an enterprise environment may be detected and displayed. For each user, one or more groups and states of that user within particular groups (e.g., member, administrator, guest administrator, etc.) may be presented. Additionally, one or more role assignment controls may be exposed by way of a selectable drop-down menu within the user interface associated with that user.

(88) For each user presented within the user scan interface **1300**, a risk and an administration score may be presented. The risk score may reflect a risk of exposure based on the roles associated with that user, while the administration score may reflect the level of access rights within the enterprise granted to the user. By adjusting one or more controls over role assignments in the drop-down menu, risk exposure and administrative access rights may be balanced appropriately by a security administrator to maintain administrative access flexibility while mitigating risk issues. An impact rating may indicate a criticality (within one or more thresholds of criticality) for adjustments to roles of users, with those users having highest criticality to possible changes to role assignments being sorted to the top of the user interface. Additionally, user profile creation and access dates may be presented, to allow the security administrator to readily view the last access times and age of various accounts.

(89) FIG. **14** shows an example threat report **1400** that may be presented within a user interface. The threat report includes, for example, threats associated with multifactor authentication, guest accounts, legacy applications, and conditional access issues. Each potential threat may have a user understandable description, a reference linked related to the threat, and a score indicating a severity of the threat to the enterprise.

(90) FIG. **15** shows a widget-based user interface **1500**. As seen in the user interface **1500**, a graphical depiction of security issues for one or more tenants may be depicted, as well as comparisons across different enterprises as to the types of threats experienced. Specific tenant devices or users may be identified as representing greater or lower threats, and a historical score may be presented to an administrative user, showing progress and managing potential security issues for the enterprise.

(91) In example embodiments the tool may have a variety of other integrations and features. For example, the tool may be integrated with existing data visualization tools such as PowerBI, Splunk, or with other threat intelligence tools such as Azure Threat Intelligence. Furthermore, controls and reporting may be output to a enterprise data store for aggregation processing, indexing, and storage for later visualization, for example using Elasticsearch and kibana. Other types of integrations are available as well.

(92) Referring to FIGS. **1-15** generally, the security assessment tool and methods of operation discussed herein have a number of advantages. In particular, the security assessment tool may be

flexibly deployed in a partially-automated or completely automated manner to reduce technology knowledge requirements of enterprise users while ensuring security measures remain in place during changes in a data, services, and physical footprint of an enterprise. The security assessment tool further incorporates knowledge of comparable enterprises and automates security updates to facilitate compliance with data security requirements, while being scalable to the size of the enterprise and having components reusable across enterprises. Furthermore, sensitive data is retained within the enterprise rather than being separately stored by the security assessment tool off-premise, thereby ensuring that no additional security vulnerability is introduced.

(93) Although the present disclosure has been described with reference to particular means, materials and embodiments, from the foregoing description, one skilled in the art can easily ascertain the essential characteristics of the present disclosure and various changes and modifications may be made to adapt the various uses and characteristics without departing from the spirit and scope of the present invention as set forth in the following claims.

## Claims

1. A method of automatically managing enterprise security for an enterprise utilizing at least one serverless service, the method comprising: executing an at least partially automated environment discovery process in which an overall security footprint of the enterprise is determined, the overall security footprint including a set of security requirements based on characteristics of the enterprise and a set of attributes associated with each of a plurality of serverless services utilized by the enterprise; automatically identifying, via an enterprise security assessment tool, one or more security configurations capable of meeting the set of security requirements of the enterprise based on the sets of attributes associated with the plurality of serverless services; and generating one or more user interfaces including a depiction of one or more security risks identified during the at least partially automated environment discovery process and a score regarding severity of the one or more security risks; wherein executing the at least partially automated environment discovery process includes: reviewing event logs generated by each of a plurality of services used by the enterprise; and at the enterprise security assessment tool, identifying one or more security applications and associated settings useable to achieve the one or more security configurations based, at least in part, on a model generated from historical security settings utilized or recommended to one or more enterprises other than the enterprise, and wherein at least one of the event logs comprises a synthetic event log generated from interactions with a simulated cloud component.
2. The method of claim 1, further comprising generating a report illustrating the overall security footprint, the one or more security applications, and settings associated with the one or more security applications useable to implement the set of security requirements across the enterprise, including across a plurality of serverless services including the at least one serverless service.
3. The method of claim 2, wherein the report includes a security score for each of a plurality of serverless services, the security score being based on a comparison of a current security configuration of the serverless service to a possible alternative security configuration.
4. The method of claim 3, wherein the possible alternative security configuration is a security configuration of another enterprise.
5. The method of claim 2, further comprising automatically configuring the one or more security applications in accordance with the one or more security configurations to achieve the set of security requirements.
6. The method of claim 5, wherein automatically configuring the one or more security applications includes recommending at least one security application in addition to a set of security applications used by the enterprise.
7. The method of claim 5, wherein automatically configuring the one or more security applications



includes calling one or more robotic process automation components from the enterprise security assessment tool.

8. The method of claim 7, wherein the one or more robotic process automation components are maintained by the enterprise.

9. The method of claim 1, wherein the overall security footprint comprises a set of applications and data managed by the enterprise including location and user accessibility of the set of applications and data, identities and access rights of users having access rights to the set of applications and data.

10. The method of claim 1, wherein the enterprise utilizes the plurality of serverless services alongside on-premises computing resources having security management software managed by the enterprise, and wherein executing the at least partially automated environment discovery process further includes assessing security requirements of each of a plurality of enterprise security applications hosted on the on-premises computing resources.

11. The method of claim 1, wherein the characteristics of the enterprise include an identity of customers of the enterprise, a data footprint of data managed by the enterprise, a data security requirement of data managed by the enterprise, and data reporting requirements of the enterprise.

12. The method of claim 11, wherein the data security requirement of the data managed by the enterprise is dictated by a set of data regulations defined externally to the enterprise.

13. An enterprise security assessment tool stored in a memory and executable on a computing device, the enterprise security assessment tool including: an application programming interface (API) providing a communicative connection to computing resources of an enterprise, the enterprise utilizing a plurality of serverless services; an assessment engine configured to: execute an at least partially automated environment discovery process in which an overall security footprint of the enterprise is determined, the overall security footprint including a set of security requirements based on characteristics of the enterprise and a set of attributes associated with each of the plurality of serverless services utilized by the enterprise; and automatically identify one or more security configurations capable of meeting the set of security requirements of the enterprise based on the sets of attributes associated with the plurality of serverless services; and generate one or more user interfaces including a depiction of one or more security risks identified during the environment discovery process and a score regarding severity of the one or more security risks wherein executing the at least partially automated environment discovery process includes: reviewing event logs generated by each of a plurality of services used by the enterprise; and at the enterprise security assessment tool, identifying one or more security applications and associated settings useable to achieve the one or more security configurations based, at least in part, on a model generated from historical security settings utilized or recommended to one or more enterprises other than the enterprise, and wherein at least one of the event logs comprises a synthetic event log generated from interactions with a simulated cloud component.

14. The enterprise security assessment tool of claim 13, wherein the computing device is remotely connected to computing resources of the enterprise.

15. The enterprise security assessment tool of claim 13, wherein the one or more security applications include at least one security application managed external to the enterprise.

16. The enterprise security assessment tool of claim 13, further comprising a robotic process automation component that is programmed to automatically configure the one or more security applications in accordance with the settings to achieve the set of security requirements.

17. The enterprise security assessment tool of claim 13, wherein the assessment engine is further configured to perform realtime monitoring of the overall security footprint of the enterprise and the settings of the one or more security applications.

18. The enterprise security assessment tool of claim 13, wherein the assessment engine is further configured to generate at least one report including a security score for each of a plurality of serverless services, the security score being based on a comparison of a current security

configuration of the serverless service to a possible alternative security configuration.

19. The enterprise security assessment tool of claim 13, further comprising a data storage attribute database of attributes associated with each of the plurality of serverless services utilized by the enterprise.

---